



# UAI

## Universidad Abierta Interamericana

### Desarrollo y arquitecturas web

**Carrera:** Ingeniería en sistemas informáticos

**Facultad:** Tecnología informática

**Tema:** Trabajo práctico grupal

**Integrantes del grupo:**

**Localización:** Centro

**Comisión:** 4-A

**Turno:** Mañana

**Año:**

**Docente:**

# ÍNDICE

|                                                                                      |    |
|--------------------------------------------------------------------------------------|----|
| ÍNDICE.....                                                                          | 2  |
| 1. Descripción global del producto .....                                             | 3  |
| Propósito .....                                                                      | 3  |
| Descripción funcional del producto .....                                             | 3  |
| Roles .....                                                                          | 4  |
| 2. Arquitectura del sistema en capas .....                                           | 4  |
| Descripción de las capas .....                                                       | 5  |
| 3. Framework y lenguaje utilizado .....                                              | 5  |
| Framework .....                                                                      | 5  |
| Lenguaje .....                                                                       | 5  |
| 4. Diagrama de capas .....                                                           | 6  |
| 5. Diagrama de clases del sistema .....                                              | 7  |
| 6. Diagrama de casos de uso del sistema.....                                         | 8  |
| 7. Base de datos.....                                                                | 9  |
| Tipo de base de datos .....                                                          | 9  |
| Sistema gestor de base de datos .....                                                | 9  |
| 8. Tipo de conexión .....                                                            | 9  |
| 9. Política de backup/restore .....                                                  | 9  |
| 10. Protección de contraseñas.....                                                   | 9  |
| 11. Olvido de contraseña .....                                                       | 9  |
| 12. Bitácora .....                                                                   | 10 |
| 13. Perfiles.....                                                                    | 10 |
| 14. Mapa de navegación del sistema .....                                             | 10 |
| 15. Captura de pantalla del login y código .....                                     | 10 |
| 16. Captura de todas las pantallas.....                                              | 10 |
| 17. Encriptación de datos.....                                                       | 10 |
| 18. Dígitos verificadores horizontales y verticales.....                             | 10 |
| 19. Casos de uso. Diagrama de actividad. Diagrama de secuencias del Login/Logut..... | 10 |
| 20. DER de todo el sistema .....                                                     | 10 |

## 3.1 Descripción global del producto

El proyecto consiste en el desarrollo de un sistema web destinado a la gestión de una librería, cuyo propósito es brindar soporte a las principales operaciones relacionadas con la administración y consulta de los libros y artículos comercializados por el negocio.

El sistema permitirá representar y organizar información correspondiente a los libros, clientes, ventas, compras, editoriales y stock, proporcionando una interfaz web para la consulta y gestión de dicha información.

El producto será desarrollado utilizando una arquitectura de cinco capas y estará orientado principalmente a la implementación de los mecanismos técnicos de seguridad, autenticación, control de acceso, integridad de datos y mantenimiento de la información.

La aplicación contará con distintos perfiles de acceso, cada uno con permisos y responsabilidades determinadas dentro del sistema.

## 3.2 Propósito

Los principales propósitos del sistema son:

1. Centralizar la información relacionada con los libros y demás datos utilizados por la librería.
2. Facilitar la consulta de los artículos disponibles, mostrando información relevante como título, ISBN, precio y stock.
3. Representar las principales operaciones del negocio relacionadas con ventas, compras, clientes y productos.
4. Proporcionar un mecanismo de autenticación que permita identificar a los usuarios que acceden al sistema.
5. Controlar el acceso a las funcionalidades de acuerdo con el perfil del usuario.
6. Incorporar mecanismos de seguridad para la protección de las contraseñas y de la información almacenada.
7. Implementar mecanismos de backup y restore que permitan preservar y recuperar la información de la base de datos.
8. Incorporar una bitácora que permita registrar determinadas operaciones realizadas en el sistema.
9. Implementar mecanismos de control de integridad mediante dígitos verificadores horizontales y verticales, permitiendo detectar modificaciones o eliminaciones no autorizadas de información en la base de datos.

## 3.3 Descripción funcional del producto

Desde el punto de vista del negocio, el sistema contempla la gestión de una librería y la información asociada a sus principales entidades. Entre las entidades consideradas se encuentran:

- Libros.
- Clientes.
- Editoriales.
- Ventas.
- Facturas.
- Compras.
- Usuarios.
- Roles.
- Permisos.

La información de los libros permitirá representar datos tales como ISBN, código, título, stock, precio de compra y precio de venta.

El sistema dispondrá de una interfaz web desde la cual los usuarios podrán acceder a las funcionalidades que correspondan según su perfil.

Las operaciones comerciales de la librería se documentan como parte del funcionamiento esperado del negocio, pero el alcance de la implementación se concentra en los mecanismos técnicos solicitados para el trabajo práctico, particularmente autenticación, perfiles, seguridad, backup y restore, bitácora y control de integridad mediante dígitos verificadores.

## 3.4 Perfiles

El sistema contará con los tres perfiles obligatorios establecidos para el proyecto:

### Cliente

Perfil destinado al usuario común del sistema. Tendrá acceso únicamente a las funcionalidades que correspondan a un usuario cliente.

En caso de detectarse problemas de integridad en la base de datos, el sistema deberá informar que el servicio no se encuentra disponible momentáneamente.

### Administrador

Perfil encargado de las tareas administrativas del sistema y de la gestión de la información que corresponda según sus permisos.

En caso de detectarse problemas en la base de datos, el administrador podrá ser informado de la existencia de dichos inconvenientes.

### Webmaster

Perfil encargado de las tareas técnicas relacionadas con el mantenimiento y seguridad del sistema.

Entre sus responsabilidades se encuentran las operaciones de backup y restore, la supervisión de la integridad de la base de datos, la consulta de la bitácora y la gestión de los mecanismos relacionados con los dígitos verificadores.

Cuando el sistema detecte modificaciones o eliminaciones externas de registros, deberá informar inmediatamente al webmaster al momento de iniciar sesión, indicando la tabla y el registro afectado cuando corresponda.

## 4. Arquitectura del sistema en capas

El sistema se desarrollará utilizando una arquitectura de cinco capas. La separación en capas permite organizar las responsabilidades del sistema, facilitar su mantenimiento y favorecer la reutilización de los componentes.

Las capas que componen la arquitectura son:

1. Capa de Entidades (BE - Business Entities)
2. Capa de Negocio (BLL - Business Logic Layer)
3. Capa de Acceso a Datos (DAL - Data Access Layer)
4. Capa de Presentación (UI - User Interface)
5. Capa de Servicios (Services)

Las capas de Entidades y Servicios poseen un carácter transversal, ya que sus componentes pueden ser utilizados por las demás capas cuando resulte necesario.

## 4.1 Descripción de las capas

### 1. Capa de Entidades (BE)

Esta capa contiene las clases que representan las entidades y los datos utilizados por el sistema.

Entre las entidades consideradas se encuentran, entre otras, Usuario, Rol, Permiso, Libro, Cliente, Venta, Factura, Compra, DetalleCompra y Editorial.

Su responsabilidad principal es representar la información que circula entre las diferentes capas del sistema, manteniendo una estructura común para el manejo de los datos.

### 2. Capa de Negocio (BLL)

Esta capa contiene la lógica de negocio del sistema y es responsable de implementar las reglas que determinan cómo deben procesarse las operaciones.

Actúa como intermediaria entre la capa de presentación y la capa de acceso a datos, recibiendo las solicitudes provenientes de la interfaz, aplicando las reglas correspondientes y solicitando a la capa de datos las operaciones necesarias.

### 3. Capa de Acceso a Datos (DAL)

Esta capa es responsable de establecer la comunicación con la base de datos y de ejecutar las operaciones necesarias sobre la información almacenada.

Entre sus responsabilidades se encuentran las operaciones de consulta, alta, modificación y eliminación de datos, así como la ejecución de los procedimientos y mecanismos necesarios para acceder a la información persistida.

### 4. Capa de Presentación (UI)

Esta capa constituye la interfaz mediante la cual los usuarios interactúan con el sistema.

Su responsabilidad es presentar la información, recibir los datos ingresados por el usuario y gestionar las interacciones correspondientes, delegando el procesamiento de las operaciones a las capas inferiores.

En esta capa se encuentran las vistas y los componentes propios de la aplicación web.

### 5. Capa de Servicios (Services)

Esta capa contiene servicios reutilizables y componentes que proporcionan funcionalidades transversales al sistema y que no pertenecen exclusivamente a la lógica específica del negocio.

Entre las funcionalidades que podrán centralizarse en esta capa se encuentran los mecanismos relacionados con seguridad, protección de contraseñas, encriptación y otros servicios técnicos necesarios para el funcionamiento general de la aplicación.

La utilización de esta capa permite centralizar funcionalidades comunes y favorecer el mantenimiento y la reutilización de los componentes del sistema.

## 5. Framework y lenguaje utilizado

### 5.1 Framework

Para el desarrollo del sistema se utilizará **ASP.NET MVC**, framework de desarrollo web perteneciente a la plataforma .NET.

ASP.NET MVC permite desarrollar aplicaciones web utilizando el patrón Modelo-Vista-Controlador (MVC), separando la presentación, el procesamiento de las solicitudes y la información utilizada por la aplicación.

El framework será utilizado para implementar la capa de presentación del sistema y gestionar la interacción entre el usuario y las demás capas de la arquitectura.

## 5.2 Lenguaje

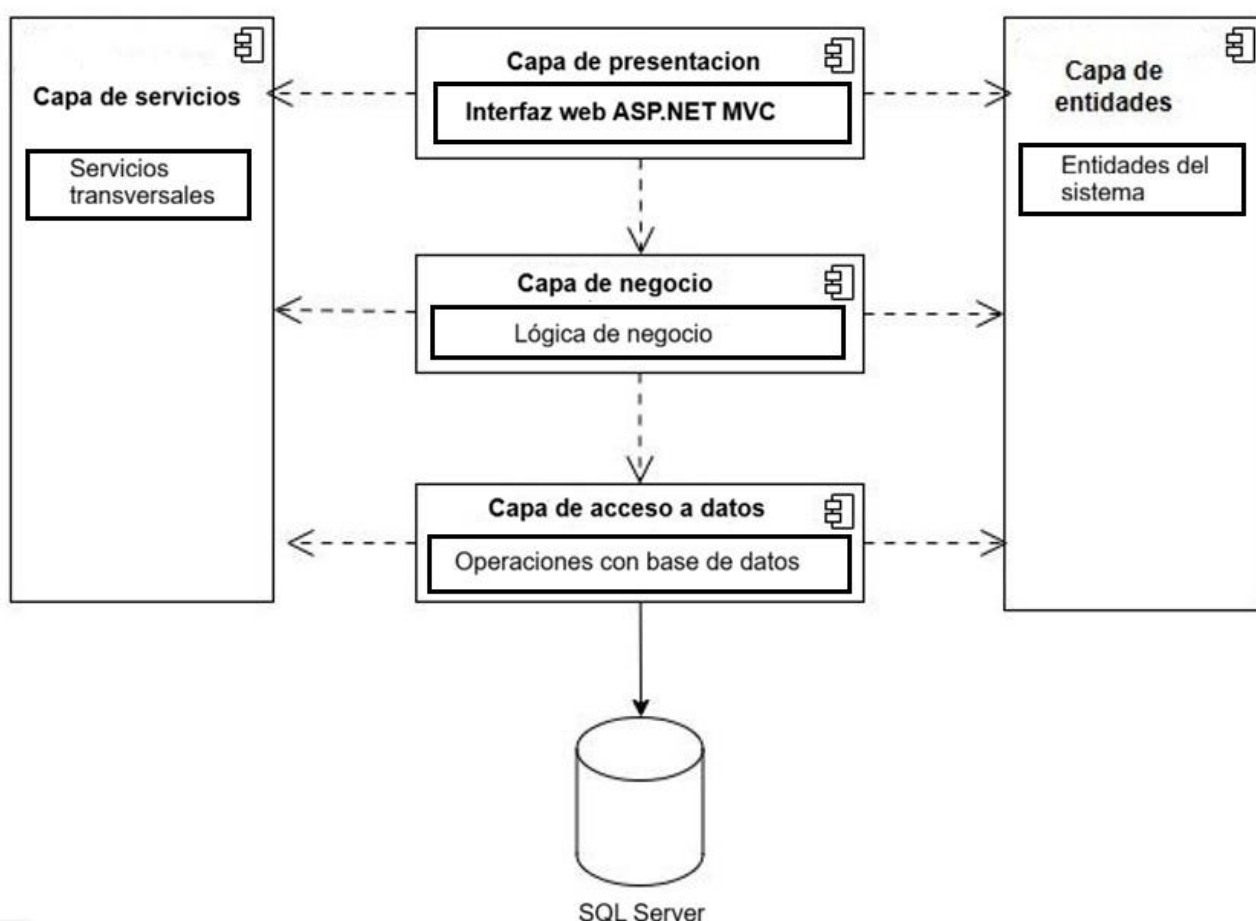
El lenguaje de programación utilizado será **C#**, lenguaje orientado a objetos perteneciente a la plataforma .NET.

C# será utilizado para implementar las clases, controladores, lógica de negocio y demás componentes necesarios para el funcionamiento de la aplicación.

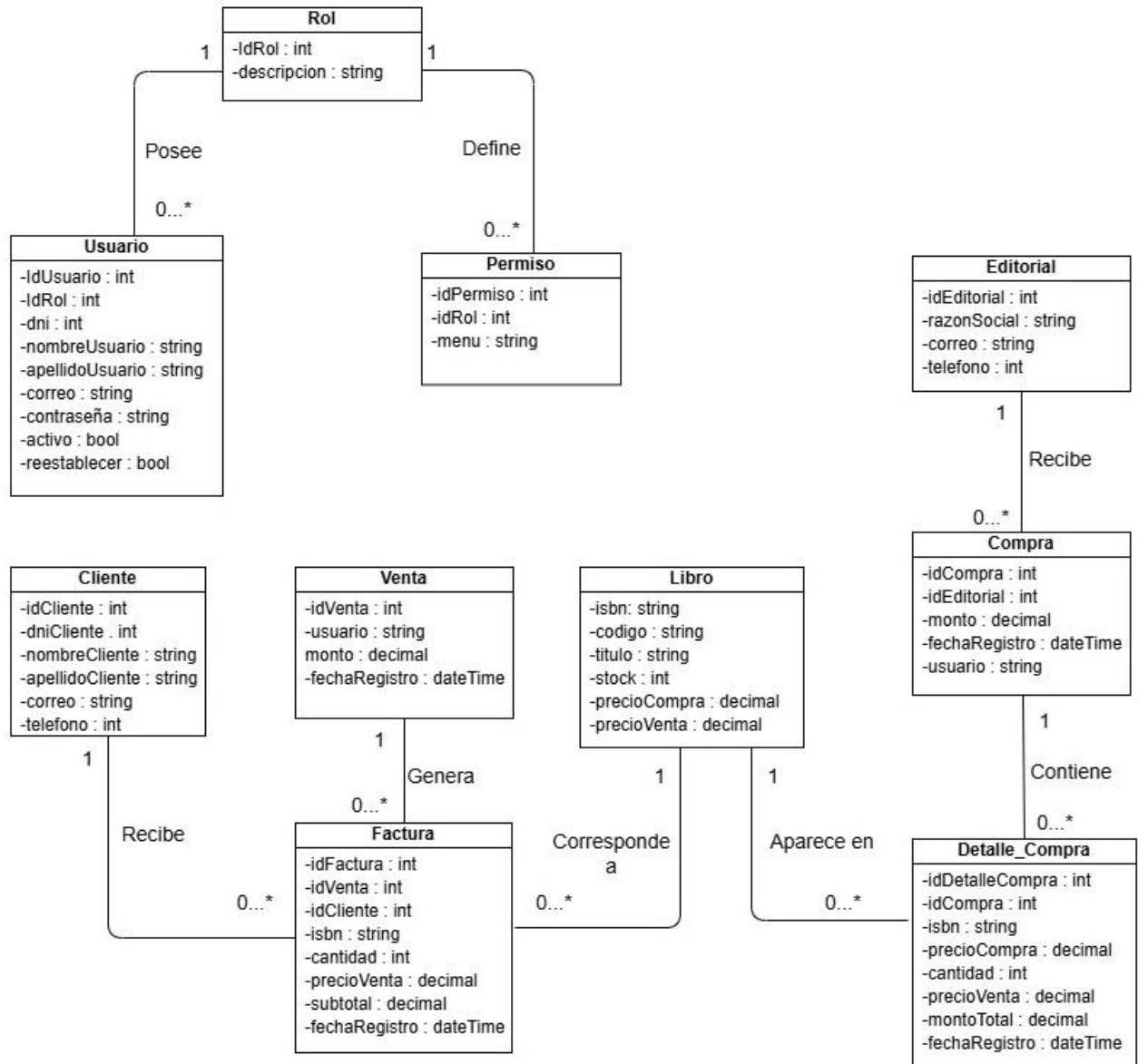
Entre sus principales características se encuentran:

- Programación orientada a objetos.
- Tipado fuerte.
- Encapsulamiento.
- Herencia y polimorfismo.
- Integración con la plataforma .NET.
- Soporte para el desarrollo de aplicaciones web mediante ASP.NET MVC.

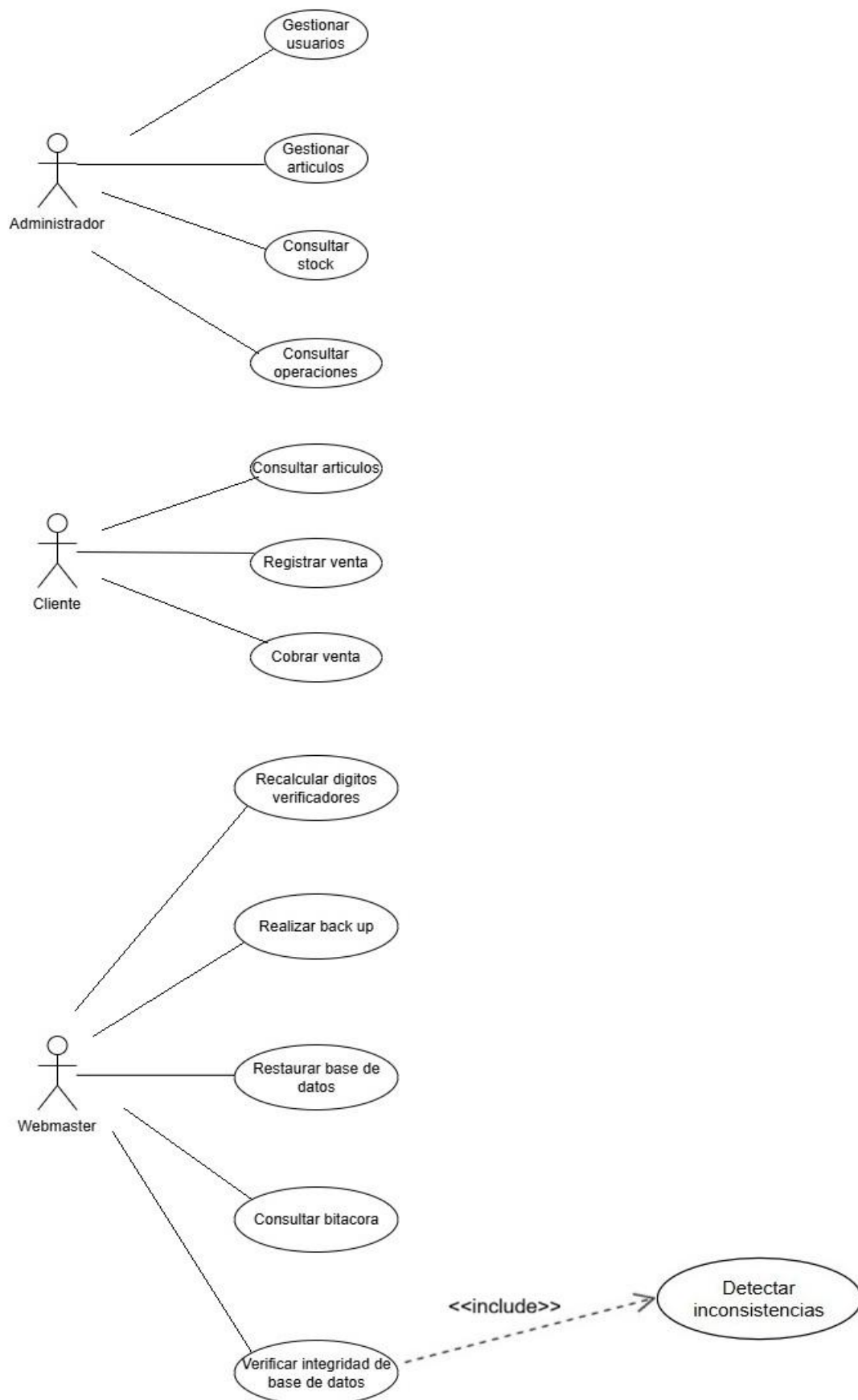
## 6. Diagrama de capas



## 7. Diagrama de clases del sistema



## 8 Diagrama de casos de uso del sistema.



## 9. Base de datos

### 9.1 Tipo de base de datos

El sistema utilizará una **base de datos relacional**, en la cual la información se organiza mediante tablas relacionadas entre sí.

El modelo de datos contempla entidades correspondientes tanto al funcionamiento del negocio como a la administración y seguridad del sistema.

Entre las principales entidades se encuentran:

- Cliente.
- Libro.
- Editorial.
- Compra.
- DetalleCompra.
- Venta.
- Factura.
- Usuario.
- Rol.
- Permiso.

Las relaciones entre las entidades se establecen mediante claves primarias y claves foráneas, permitiendo mantener la integridad de los datos y evitar inconsistencias en las relaciones entre las diferentes tablas.

El modelo contempla, entre otras, la relación entre usuarios y roles, roles y permisos, editoriales y compras, compras y sus detalles, libros y detalles de compra, así como clientes, libros, ventas y facturas.

### 9.2 Sistema gestor de base de datos

Para la implementación del sistema se utilizará **Microsoft SQL Server** como sistema gestor de base de datos.

SQL Server será responsable del almacenamiento y administración de la información persistente utilizada por la aplicación.

La administración y mantenimiento de la base de datos se realizará mediante **SQL Server Management Studio (SSMS)**, herramienta que permite crear y administrar la base de datos, ejecutar consultas SQL, gestionar objetos y realizar tareas administrativas.

La aplicación web accederá a SQL Server mediante la capa de acceso a datos (DAL), manteniendo separada la lógica de acceso a la información respecto de la interfaz y de la lógica de negocio.

### 9.3 Estructura de la base de datos

La base de datos estará compuesta por tablas relacionadas que representan las principales entidades del sistema.

Las tablas correspondientes al negocio permiten almacenar información sobre libros, clientes, editoriales, compras, ventas y facturas.

Por otra parte, las tablas Usuario, Rol y Permiso permiten administrar los usuarios del sistema y establecer los permisos correspondientes a cada perfil.

El diseño completo de las tablas y sus relaciones se representa mediante el **Diagrama Entidad-Relación (DER)** del sistema.

## 10. Tipo de conexión

La aplicación web utilizará una conexión mediante **ADO.NET** para comunicarse con el sistema gestor de base de datos Microsoft SQL Server.

La comunicación con la base de datos se realizará desde la **Capa de Acceso a Datos (DAL)**, manteniendo separada la lógica de acceso a la información de la capa de presentación y de la lógica de negocio.

### 10.1 Método de conexión

Para establecer la comunicación con SQL Server se utilizará la clase `SqlConnection`, perteneciente a la biblioteca `System.Data.SqlClient`.

La cadena de conexión se encuentra definida en el archivo de configuración de la aplicación web (`Web.config`) y es obtenida por la clase de conexión de la capa de datos.

Una vez establecida la conexión, la aplicación utilizará objetos `SqlCommand` para ejecutar consultas SQL y procedimientos almacenados.

Para las operaciones de consulta que requieren recorrer los resultados obtenidos se utilizará `SqlDataReader`.

El acceso a la base de datos se realizará utilizando bloques `using`, permitiendo que los recursos asociados a la conexión sean liberados una vez finalizada la operación.

### 10.2 Circunstancias de utilización

La conexión a la base de datos se establecerá cuando alguna funcionalidad del sistema requiera acceder a información persistida.

Entre las principales situaciones se encuentran:

- Consulta de usuarios para realizar la autenticación.
- Consulta y gestión de información de los artículos.
- Alta, modificación y eliminación de registros cuando corresponda.
- Consulta de información relacionada con clientes, compras, ventas y demás entidades del sistema.
- Ejecución de operaciones administrativas que requieran acceder a la base de datos.
- Ejecución de mecanismos técnicos que requieran verificar o modificar información almacenada.

La conexión no permanecerá abierta de manera permanente. Se abrirá cuando sea necesaria para ejecutar una operación y se cerrará una vez finalizado el acceso a los datos.

### 10.3 Ubicación dentro de la arquitectura

El acceso a la base de datos estará centralizado en la **Capa de Acceso a Datos (DAL)**.

La comunicación seguirá, de manera general, el siguiente flujo:

#### **Capa de Presentación (UI) → Capa de Negocio (BLL) → Capa de Acceso a Datos (DAL) → SQL Server**

De esta manera, la interfaz de usuario y la lógica de negocio no acceden directamente a la base de datos, manteniendo separadas las responsabilidades de cada capa.

## 11. Política de backup/restore.

El sistema contará con mecanismos de **backup y restore de la base de datos**, destinados a preservar la información almacenada y permitir su recuperación ante situaciones que comprometan su integridad. Estas operaciones estarán restringidas al perfil **Webmaster**, debido a que forman parte de las tareas técnicas de mantenimiento y recuperación del sistema.

### 11.1 Política de backup

El backup consistirá en la generación de una copia de respaldo de la base de datos del sistema.

La realización del backup tendrá como objetivo disponer de una copia de la información que permita recuperar el estado de la base de datos ante una eventual pérdida, modificación no autorizada o corrupción de los datos.

El Webmaster podrá ejecutar manualmente la operación de backup desde el sistema.

Cada operación de backup deberá quedar registrada en la bitácora, incluyendo como mínimo la fecha y hora de la operación y el usuario responsable de ejecutarla.

El respaldo deberá conservarse de manera independiente respecto de la información que se encuentra actualmente en uso por la aplicación, de modo que pueda utilizarse posteriormente para una operación de restauración.

### 11.2 Política de restore

La operación de restore permitirá recuperar la base de datos a partir de un backup previamente generado.

Esta operación estará disponible exclusivamente para el Webmaster.

El restore podrá utilizarse, entre otras situaciones, cuando el sistema detecte inconsistencias en la información almacenada como consecuencia de modificaciones o eliminaciones realizadas fuera de la aplicación.

Ante la detección de inconsistencias, el sistema deberá informar al Webmaster sobre el problema encontrado y ofrecer la posibilidad de restaurar la base de datos desde un respaldo disponible, de acuerdo con el procedimiento establecido para el sistema.

La restauración deberá dejar constancia de la operación realizada en la bitácora, indicando como mínimo la fecha y hora y el usuario responsable.

### 11.3 Backup y restore ante problemas de integridad

Los mecanismos de backup y restore estarán relacionados con el sistema de control de integridad mediante dígitos verificadores.

Cuando el Webmaster vuelva a iniciar sesión luego de que se hayan producido modificaciones o eliminaciones externas de registros, el sistema verificará la integridad de la información y comunicará los inconvenientes detectados.

En caso de existir inconsistencias, el Webmaster podrá decidir entre las alternativas disponibles, entre ellas restaurar la base de datos utilizando un backup previamente generado.

De esta manera, el backup constituye el mecanismo de respaldo y el restore el mecanismo de recuperación de la información ante una situación que afecte la integridad de la base de datos.

## 12. Protección de contraseñas.

Las contraseñas de los usuarios no serán almacenadas en texto plano en la base de datos. Para protegerlas se utilizará un mecanismo de **hash criptográfico**, de manera que el sistema almacene el resultado del procesamiento de la contraseña y no su valor original.

### 12.1 Algoritmo utilizado

La implementación actual del proyecto utiliza el algoritmo **SHA-256 (Secure Hash Algorithm 256 bits)** para generar el hash de las contraseñas.

El procedimiento consiste en convertir la contraseña ingresada por el usuario a una secuencia de bytes mediante codificación UTF-8 y aplicar posteriormente SHA-256. El resultado se representa mediante una cadena hexadecimal.

El hash será generado antes de almacenar una nueva contraseña y también antes de comparar una contraseña durante el proceso de autenticación.

De esta manera, durante el Login el sistema no compara directamente la contraseña ingresada con una contraseña almacenada en texto plano, sino que genera su hash mediante SHA-256 y compara dicho resultado con el valor almacenado en la base de datos.

El mismo mecanismo se utilizará en las operaciones de cambio y restablecimiento de contraseña.

### 12.2 Protección durante el almacenamiento

Las contraseñas almacenadas en la base de datos deberán encontrarse representadas mediante su valor hash y no mediante el texto original ingresado por el usuario.

El sistema no deberá mostrar la contraseña almacenada ni permitir su recuperación en texto plano.

Las operaciones relacionadas con las contraseñas deberán realizarse mediante las capas correspondientes de la arquitectura, centralizando el mecanismo de hashing en la capa de Servicios.

### 12.3 Política de contraseñas

El sistema establecerá una política de contraseñas destinada a reducir el riesgo de acceso no autorizado.

Las contraseñas deberán:

- Tener una longitud mínima de 8 caracteres.
- Contener al menos una letra mayúscula.
- Contener al menos una letra minúscula.
- Contener al menos un número.
- Contener al menos un carácter especial.
- No coincidir con el correo electrónico del usuario.
- No ser almacenadas ni transmitidas como texto plano.

Cuando un usuario deba restablecer su contraseña, deberá establecer una nueva contraseña que cumpla con la política definida.

El sistema deberá verificar el cumplimiento de estos requisitos antes de aceptar una nueva contraseña.

### 12.4 Cambio y restablecimiento de contraseña

El sistema contempla mecanismos para el cambio y restablecimiento de contraseñas.

Durante el cambio de contraseña, el sistema verificará la contraseña actual, validará que la nueva contraseña y su confirmación coincidan y, posteriormente, almacenará el hash de la nueva contraseña.

En caso de restablecimiento, el sistema identificará al usuario mediante su correo electrónico y permitirá establecer una nueva contraseña de acuerdo con la política definida.

## 13. Olvido de contraseña.

El sistema contará con un mecanismo de recuperación de acceso para los usuarios que hayan olvidado su contraseña.

El proceso se iniciará desde la pantalla de Login, mediante la opción "**¿Olvidaste tu contraseña?**".

### 13.1 Solicitud de recuperación

El usuario deberá ingresar la dirección de correo electrónico asociada a su cuenta.

El sistema verificará si existe un usuario registrado con dicha dirección de correo.

Si no existe un usuario asociado, se informará que no se encontró una cuenta relacionada con el correo ingresado.

Si el correo corresponde a un usuario existente, se iniciará el proceso de restablecimiento.

### 13.2 Generación de una contraseña temporal

Ante una solicitud válida, el sistema generará una contraseña temporal.

La contraseña temporal será almacenada en la base de datos mediante su correspondiente valor hash, utilizando el mecanismo de protección de contraseñas definido para el sistema.

La cuenta del usuario será marcada para indicar que requiere el cambio de contraseña antes de continuar utilizando normalmente el sistema.

### 13.3 Envío de la contraseña temporal

La contraseña temporal será enviada a la dirección de correo electrónico asociada a la cuenta del usuario.

El usuario utilizará dicha contraseña temporal para realizar un nuevo inicio de sesión.

### 13.4 Cambio obligatorio de contraseña

Cuando el usuario inicie sesión utilizando una contraseña temporal y la cuenta se encuentre marcada para restablecimiento, el sistema no permitirá continuar directamente hacia la aplicación.

En su lugar, será dirigido al formulario de **Cambio de contraseña**.

En dicho formulario deberá:

1. Ingresar la contraseña actual.
2. Ingresar una nueva contraseña.
3. Confirmar la nueva contraseña.

El sistema verificará que la contraseña actual sea correcta y que la nueva contraseña y su confirmación coincidan.

La nueva contraseña deberá cumplir con la política de contraseñas definida en el punto 12.

Una vez completado correctamente el proceso, el sistema almacenará el hash de la nueva contraseña y quitará la marca de restablecimiento de la cuenta.

### 13.5 Consideraciones de seguridad

El mecanismo de recuperación deberá evitar almacenar contraseñas en texto plano en la base de datos. Las credenciales utilizadas para el servicio de correo no deberán quedar expuestas directamente en el código fuente de la aplicación.

Durante la etapa de implementación se revisará y ajustará el mecanismo de recuperación existente para adecuarlo a las políticas de seguridad definidas para el sistema.

## 14. Bitácora. Que se almacena y filtros de consulta.

El sistema contará con una **bitácora de operaciones** destinada a registrar eventos relevantes producidos durante el uso y mantenimiento de la aplicación.

La bitácora tendrá como objetivo proporcionar trazabilidad sobre las operaciones realizadas por los usuarios y facilitar la supervisión de las actividades administrativas y técnicas del sistema.

La información registrada podrá ser consultada por los perfiles que cuenten con los permisos correspondientes, especialmente por el Administrador y el Webmaster.

### 14.1 Información almacenada

Por cada evento registrado se almacenará, como mínimo, la siguiente información:

- Fecha y hora en que se produjo el evento.
- Usuario que realizó la operación.
- Perfil o rol del usuario.
- Tipo de operación realizada.
- Módulo o funcionalidad involucrada.
- Resultado de la operación.
- Descripción o detalle del evento.
- Identificador del registro afectado, cuando corresponda.
- Tabla afectada, cuando corresponda.

El registro de la tabla y del identificador afectado será particularmente importante para los eventos relacionados con la integridad de la base de datos, ya que permitirá informar qué tabla y qué registro fueron modificados o eliminados de forma externa.

### 14.2 Operaciones registradas

La bitácora registrará las operaciones relevantes para la administración, seguridad y control del sistema.

Entre ellas se contemplan:

- Inicio de sesión.
- Cierre de sesión.
- Cambios de contraseña.
- Recuperación o restablecimiento de contraseña.
- Altas, modificaciones y bajas de usuarios.
- Operaciones administrativas relevantes.
- Ejecución de backup.
- Ejecución de restore.
- Verificación de integridad de la base de datos.
- Detección de registros modificados o eliminados externamente.
- Recalculo de dígitos verificadores.

Cuando se detecte una inconsistencia en la base de datos, la bitácora deberá conservar la información necesaria para identificar la tabla y el registro afectado, y registrar el evento como una situación de integridad.

## 14.3 Filtros de consulta

La consulta de la bitácora contará con filtros que permitan localizar eventos específicos sin necesidad de recorrer todo el historial.

Los principales filtros serán:

- **Fecha desde y fecha hasta:** permite consultar eventos producidos dentro de un período determinado.
- **Usuario:** permite localizar las operaciones realizadas por un usuario específico.
- **Perfil:** permite filtrar por el rol del usuario que realizó la operación.
- **Tipo de operación:** permite consultar, por ejemplo, Login, Logout, Backup, Restore, cambio de contraseña o modificación de información.
- **Módulo:** permite identificar el sector del sistema en el que se produjo el evento.
- **Resultado:** permite distinguir entre operaciones realizadas correctamente y operaciones que produjeron errores o inconsistencias.

Los filtros podrán utilizarse de manera combinada para acotar los resultados de la consulta.

## 14.4 Acceso a la bitácora

El acceso a la información registrada en la bitácora estará restringido de acuerdo con los permisos definidos para cada perfil.

El Webmaster tendrá acceso a la información necesaria para supervisar las operaciones técnicas y los eventos relacionados con la integridad de la base de datos.

El Administrador podrá consultar los eventos administrativos que correspondan según sus permisos.

El usuario cliente no tendrá acceso a la bitácora.

La bitácora deberá conservar los registros históricos y evitar que los usuarios comunes puedan modificarlos desde la aplicación.

# 15. Perfiles: usuario, administrador y webmaster.

## Usuario familia patente.

El sistema contará con tres perfiles de acceso obligatorios:

- **Usuario/Cliente**
- **Administrador**
- **Webmaster**

Cada usuario estará asociado a un perfil, y dicho perfil determinará las funcionalidades a las que podrá acceder dentro del sistema.

La asignación de permisos se organizará mediante una estructura de **familias y patentes**, con el objetivo de agrupar funcionalidades relacionadas y establecer permisos específicos sobre cada operación.

## 15.1 Usuario

El usuario representa a una persona identificada dentro del sistema mediante sus credenciales de acceso.

Cada usuario tendrá asociado un único perfil, el cual determinará sus permisos y las funcionalidades disponibles.

El usuario deberá autenticarse mediante el mecanismo de Login antes de acceder a las funcionalidades protegidas del sistema.

## 15.2 Administrador

El perfil Administrador tendrá permisos orientados a la administración funcional del sistema. Entre sus principales responsabilidades se encontrarán:

- Gestionar usuarios.
- Gestionar artículos.
- Consultar información del sistema.
- Consultar stock.
- Acceder a las funcionalidades administrativas que le sean asignadas mediante sus permisos.

El Administrador no tendrá acceso a las operaciones técnicas exclusivas del Webmaster, salvo que un permiso específico fuera definido para ello.

## 15.3 Webmaster

El perfil Webmaster tendrá permisos orientados a las tareas técnicas, de mantenimiento, seguridad e integridad del sistema.

Entre sus principales responsabilidades se encontrarán:

- Ejecutar backups.
- Restaurar la base de datos.
- Consultar la bitácora.
- Verificar la integridad de la base de datos.
- Atender las inconsistencias detectadas mediante los dígitos verificadores.
- Recalcular los dígitos verificadores cuando corresponda.

Estas funcionalidades serán de acceso restringido debido a su impacto sobre la seguridad y la información almacenada.

## 15.4 Familias

Una familia representa una agrupación lógica de funcionalidades relacionadas con una determinada área del sistema.

Las familias permitirán organizar los permisos y facilitar su administración.

Entre las familias previstas para el sistema podrán encontrarse:

- **Administración:** funcionalidades relacionadas con usuarios y configuración.
- **Productos:** funcionalidades relacionadas con artículos y stock.
- **Consultas:** funcionalidades destinadas a la visualización de información.
- **Seguridad:** funcionalidades relacionadas con autenticación, contraseñas y bitácora.
- **Mantenimiento:** funcionalidades relacionadas con backup, restore e integridad de la base de datos.

Las familias constituyen una forma de organizar las funcionalidades y no representan por sí mismas un permiso de ejecución.

## 15.5 Patentes

Una patente representa un permiso individual asociado a una funcionalidad concreta del sistema.

Cada patente determinará si un perfil puede ejecutar una determinada operación.

Por ejemplo:

- Gestionar usuarios.
- Gestionar artículos.
- Consultar stock.
- Consultar bitácora.
- Realizar backup.
- Restaurar base de datos.
- Verificar integridad.
- Recalcular dígitos verificadores.

Las patentes estarán agrupadas dentro de familias y serán asignadas a los perfiles según las responsabilidades correspondientes.

## 15.6 Relación entre usuario, perfil, familia y patente

La estructura de autorización seguirá conceptualmente el siguiente esquema:

**Usuario → Perfil → Patentes**

Las patentes estarán organizadas dentro de familias para facilitar la administración de los permisos:

**Perfil → Familia → Patente**

De esta manera, el usuario no tendrá permisos definidos directamente sobre cada funcionalidad de manera aislada, sino que heredará las autorizaciones correspondientes al perfil que tenga asignado. Por ejemplo:

### **Webmaster**

- Familia Mantenimiento
- Patente Realizar backup
- Patente Restaurar base de datos

### **Administrador**

- Familia Administración
- Patente Gestionar usuarios
- Patente Gestionar artículos

### **Usuario/Cliente**

- Familia Consultas
- Patente Consultar artículos

La aplicación verificará los permisos correspondientes antes de permitir el acceso a las funcionalidades protegidas.

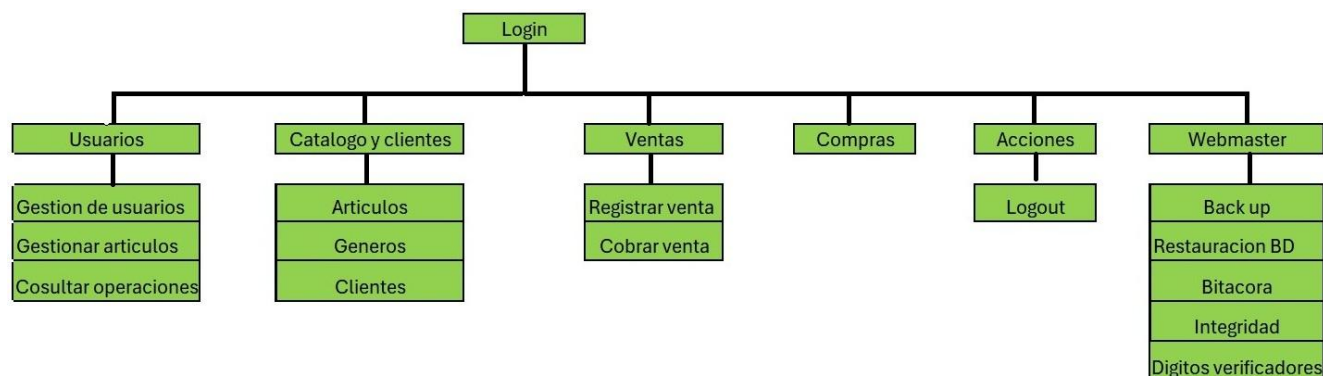
## 15.7 Implementación conceptual

La gestión de perfiles y permisos se resolverá mediante una estructura de roles y permisos dentro del sistema.

La base de datos contempla las entidades Usuario, Rol y Permiso, permitiendo asociar cada usuario a un rol y organizar los permisos correspondientes a cada rol.

No se establece para este proyecto la utilización obligatoria de un patrón de diseño específico para implementar esta funcionalidad. La solución deberá priorizar la claridad, el mantenimiento y la correspondencia con la estructura de permisos definida para el sistema.

## 16. Mapa de navegación del sistema.



## 15. Captura de pantalla del login y código

## 16. Captura de todas las pantallas

## 17. Encriptación de datos. Qué métodos se utilizan.

El sistema diferenciará entre los mecanismos utilizados para la protección de contraseñas y los mecanismos destinados a proteger información que, por su naturaleza, deba almacenarse de forma segura y posteriormente pueda ser recuperada.

### 19.1 Protección mediante hash

Las contraseñas de los usuarios no serán almacenadas en texto plano.

Para su protección se utilizará el algoritmo **SHA-256**, tal como se especifica en el apartado correspondiente a la protección de contraseñas.

El resultado del proceso de hashing no podrá utilizarse para recuperar la contraseña original, por lo que este mecanismo será utilizado exclusivamente para la protección de credenciales y no para datos que deban ser recuperados en su forma original.

### 19.2 Encriptación de datos

Para aquellos datos sensibles que requieran protección mediante un mecanismo reversible, se prevé utilizar **encriptación simétrica mediante AES (Advanced Encryption Standard)**.

La encriptación simétrica permitirá transformar un dato original en un valor cifrado que no podrá ser interpretado directamente y que podrá ser recuperado posteriormente mediante la clave correspondiente.

La aplicación deberá mantener separadas las claves utilizadas para la encriptación de los datos protegidos y no deberá almacenar dichas claves junto con la información cifrada.

## 19.3 Criterio de utilización

La utilización de cada mecanismo dependerá del tipo de información:

- **Contraseñas:** SHA-256 mediante hashing, debido a que no es necesario recuperar la contraseña original.
- **Datos que deban recuperarse posteriormente:** AES mediante encriptación simétrica, cuando corresponda protegerlos frente a accesos no autorizados.

De esta manera, el sistema utilizará el mecanismo de protección adecuado según la naturaleza del dato.

## 19.4 Implementación

La funcionalidad de encriptación se centralizará en la **Capa de Servicios**, evitando que cada módulo de la aplicación implemente su propio mecanismo de protección.

La implementación deberá garantizar que los datos sensibles no sean almacenados innecesariamente en texto plano y que las claves utilizadas para la encriptación sean protegidas adecuadamente.

La definición de los datos que requerirán encriptación y la implementación definitiva del mecanismo serán verificadas durante la etapa de desarrollo del software.

# 20. Dígitos verificadores horizontales y verticales.

El sistema incorporará un mecanismo de control de integridad de la información almacenada en la base de datos mediante el uso de **dígitos verificadores horizontales y verticales**.

El objetivo de este mecanismo será detectar modificaciones o eliminaciones realizadas sobre los registros de la base de datos fuera de los procedimientos normales de la aplicación.

El sistema utilizará los valores obtenidos a partir de la información almacenada para generar y comparar los correspondientes verificadores de integridad.

## 20.1 Dígito verificador horizontal

El dígito verificador horizontal estará asociado a cada registro controlado de una tabla.

Su finalidad será representar un valor de control calculado a partir de los datos que componen dicho registro.

Cuando el sistema realice una verificación de integridad, volverá a calcular el valor correspondiente al registro y lo comparará con el valor de control almacenado.

Si ambos valores no coinciden, el sistema considerará que el registro presenta una inconsistencia y lo identificará como un registro posiblemente modificado.

De esta manera, el control horizontal permitirá localizar específicamente los registros que hayan sufrido modificaciones.

## 20.2 Dígito verificador vertical

El dígito verificador vertical tendrá como objetivo controlar la integridad del conjunto de registros de una tabla.

Para ello se generará un valor de control a partir de los valores correspondientes a los registros que forman parte de la tabla.

Durante una verificación, el sistema volverá a calcular el valor de control y lo comparará con el valor registrado previamente.

Una diferencia permitirá detectar que el contenido global de la tabla no coincide con el estado esperado.

El control vertical resultará especialmente útil para detectar situaciones en las que se haya producido la eliminación o incorporación no autorizada de registros, además de servir como control complementario frente a modificaciones de datos.

## 20.3 Verificación de integridad

La verificación de integridad será realizada por el sistema cuando corresponda, y tendrá especial importancia durante el inicio de sesión del Webmaster.

El proceso general será:

1. Obtener los datos actuales de las tablas sometidas a control.
2. Calcular nuevamente los dígitos verificadores.
3. Comparar los valores calculados con los valores de control almacenados.
4. Determinar si existen diferencias.
5. Identificar la tabla y el registro afectados cuando sea posible.
6. Registrar el evento en la bitácora.
7. Informar inmediatamente al Webmaster sobre la inconsistencia detectada.

El sistema deberá permitir distinguir, cuando pueda determinarse, entre una modificación de un registro y la eliminación de un registro.

## 20.4 Relación con la bitácora

Toda inconsistencia detectada mediante los mecanismos de verificación deberá quedar registrada en la bitácora.

El registro deberá conservar, como mínimo, información sobre:

- Tabla afectada.
- Registro afectado, cuando pueda determinarse.
- Tipo de inconsistencia detectada.
- Fecha y hora de detección.
- Usuario que realizó la verificación.

Esto permitirá mantener trazabilidad sobre los problemas de integridad encontrados en la base de datos.

## 20.5 Acción ante una inconsistencia

Cuando el sistema detecte una inconsistencia, deberá mostrarla inmediatamente al Webmaster al iniciar sesión.

La ventana de aviso deberá informar la tabla y el registro afectados, cuando esta información pueda determinarse.

Desde dicha ventana, el Webmaster podrá seleccionar la acción correspondiente entre las alternativas previstas por el sistema:

- Cancelar la operación y conservar el estado actual de la base de datos.
- Recalcular los dígitos verificadores cuando la modificación detectada sea intencional y deba aceptarse como nuevo estado válido.
- Restaurar la base de datos utilizando un backup previamente generado.

La operación elegida deberá quedar registrada en la bitácora.

## 20.6 Alcance de la implementación

Los mecanismos de verificación deberán ser implementados para aquellas tablas que sean seleccionadas para formar parte del control de integridad del sistema.

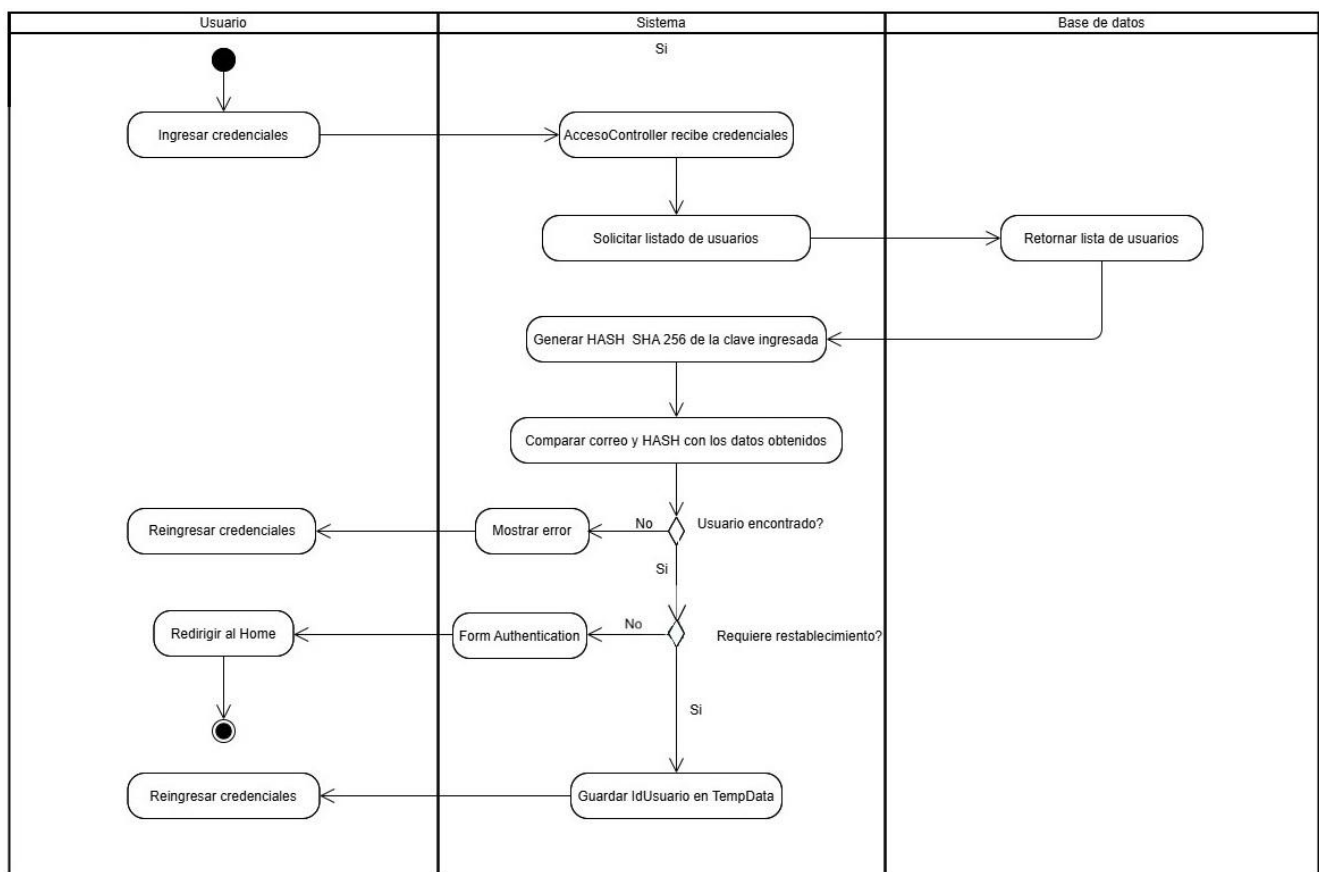
La definición exacta de los campos utilizados para calcular cada verificador y del algoritmo matemático empleado se establecerá durante la etapa de implementación, verificando que el mecanismo permita detectar correctamente las modificaciones y eliminaciones externas exigidas para la demostración del sistema.

## 20. Casos de uso. Diagrama de actividad. Diagrama de secuencias del Login/Logout.

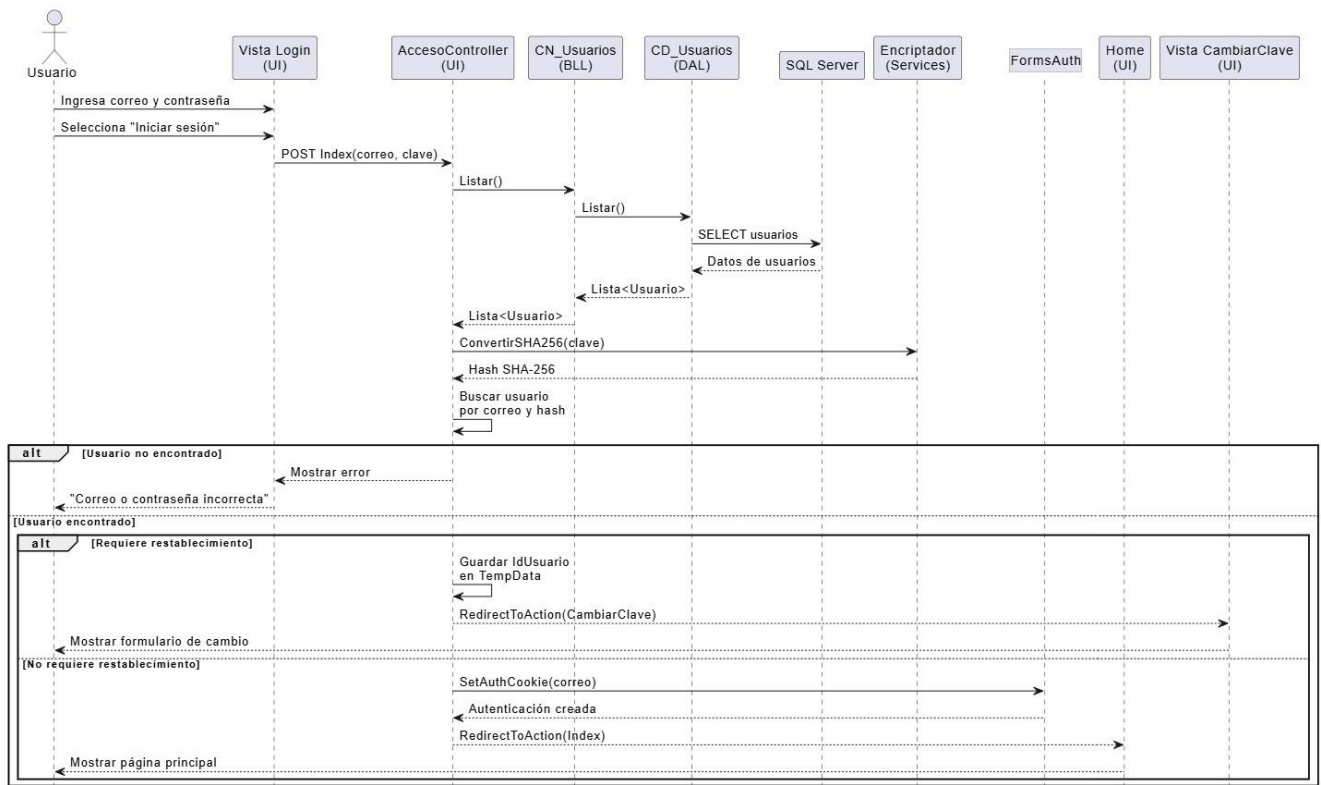
### 20.1 Diagrama de caso de uso Realizar Login



### 20.2 Diagrama de caso de actividad de caso de uso Realizar Login.



## 20.3 Diagrama de caso de secuencia de caso de uso Realizar Login.



## 20.4 Diagrama de caso de uso Realizar Logout.



## 20. DER de todo el sistema

